Pineda Salon Co.

Data Protection Impact Assessment: SkinRead Diagnostic Kiosk

Assessment period: 2026-07-06 to 2026-09-11 · Report date: 2026-09-25 · Status: Draft v0.6, pending owner and counsel review

Fictional organization. Created for portfolio demonstration purposes. No real client, biometric, or personal data is referenced.

1. Scope

Pineda Salon Co. operates nine salons: seven in Brevard and Orange counties, Florida, and two in the Houston area, Texas (Kemah and Pearland). Six locations employ stylists as W-2 staff. Three (Cocoa Village, Merritt Island, Pearland) run on booth rental, where stylists are independent businesses leasing chairs.

In February 2026 the company installed SkinRead kiosks, supplied by Oduya Imaging, Inc., at all nine locations. This assessment covers the kiosk capture flow, transmission to Oduya Imaging's hosted analysis service, storage of results in the company's third-party booking platform, and client photos taken by stylists during services.

Out of scope: payment card processing (covered by the annual PCI DSS self-assessment) and employee HR data.

2. Method and rating scale

Evidence came from document review, vendor console inspection, and interviews. Stylist interviews covered six of 23 stylists: whoever was on shift during site visits. This is a convenience sample and may not represent practice at locations with lighter visit coverage.

Statutory text was checked against the primary sources listed in §10 where available. Where only secondary sources were available, the determination is referred to counsel.

Rating	Meaning
High	Likely current noncompliance with an applicable law, or exposure of biometric data with no enforceable control
Moderate	Control gap with a plausible path to regulatory or client harm, where exposure is bounded
Low	Control weakness with limited exposure or an existing partial mitigation
Unable to test	Evidence needed to reach a determination was not provided

3. How data moves

1. The client stands at the kiosk and a 2D facial photo is taken.
2. If the client taps "Advanced scan," a 3D face-geometry capture is also taken.
3. Both go over the vendor API to Oduya Imaging, which returns a skin and scalp report with product suggestions.
4. The report and a cropped thumbnail are written to the client's booking record.
5. Oduya Imaging keeps the full-resolution 2D image and the 3D capture, and uses them to train its models.

From go-live on 2026-02-17 through 2026-08-31: 3,118 scans from 2,467 unique clients. Of those, 214 scans from 188 clients included the 3D capture, and 41 of those scans (37 clients) were taken at the two Texas locations.

ID	Data element	Sensitivity	Held by	Retention today
D-1	2D facial image, full resolution	Sensitive	Oduya Imaging	Indefinite (F-01)
D-2	3D face-geometry capture	Biometric identifier in TX	Oduya Imaging	Indefinite (F-01)
D-3	Cropped thumbnail	Sensitive	Booking platform	No schedule (F-05)
D-4	Skin/scalp report	Sensitive	Booking platform	No schedule (F-05)
D-5	Name, phone, email, visit history	Personal	Booking platform	Account lifetime

ID	Data element	Sensitivity	Held by	Retention today
D-6	Before/after service photos	Sensitive	Stylists' personal phones	Uncontrolled (F-03)

4. Necessity and proportionality

The business purpose is a skin and scalp report that drives service and retail recommendations. The report can be generated without Oduya Imaging keeping images after analysis, and the vendor's documentation lists a "process and discard" mode that Pineda did not enable. The 3D capture adds facial contour measurement used for makeup recommendations. The company's retail report attributes $38,412 in product sales to kiosk recommendations from February through August. It does not track how much of that came from 3D scans, so the business value of D-2 specifically is unknown.

Assessor view: long-term retention of D-1 and D-2 by the vendor is not necessary for Pineda's purpose. Collection of D-2 may be proportionate in Florida but has not been shown to be worth its compliance cost in Texas.

5. Regulatory applicability

Framework	Determination	Basis
Texas CUBI, Tex. Bus. & Com. Code § 503.001	Applies to D-2 at Kemah and Pearland. Application to D-1 referred to counsel	Covers records of face geometry captured for a commercial purpose. § 503.001(b) requires notice and consent before capture. § 503.001(c)(1) bars disclosure to another person except in four cases: consent for identification after disappearance or death, completing a financial transaction the individual requested, disclosure required or permitted by other statute, or law enforcement under a warrant. None describes a vendor processing images on Pineda's behalf. § 503.001(c)(3) requires destruction within a reasonable time and no later than one year after the purpose expires. § 503.001(d) sets a civil penalty of up to $25,000 per violation, recoverable by the Attorney General
CUBI amendments by HB 149 (TRAIGA), effective 2026-01-01	Likely covers Oduya Imaging's model-training use. Does not appear to cover Pineda's capture for skin analysis. Referred to counsel	Verified against the enrolled bill. New § 503.001(e)(2) exempts the training, processing, or storage of biometric identifiers involved in developing, training, evaluating, disseminating, or otherwise offering AI models or systems, unless a system is used or deployed to uniquely identify a specific individual. SkinRead does not identify individuals. New § 503.001(f) pulls an identifier captured for training back under the possession, destruction, and penalty provisions if it is later used for a commercial purpose outside those exemptions. Whether "otherwise offering" reaches a retailer deploying a vendor's system is unsettled
TRAIGA § 552.054(c), effective 2026-01-01	Applies wherever a CUBI violation is found	A violation of § 503.001 is also a violation of § 552.054, which routes it into TRAIGA's penalty scheme: $10,000 to $12,000 per curable violation, $80,000 to $200,000 per uncurable violation, and $2,000 to $40,000 per day for a continuing violation. The AG has exclusive enforcement and must give written notice with a 60-day cure period first. TRAIGA's own definition of "biometric data" in § 552.054(a) excludes photographs and data generated from photographs, which does not control the CUBI analysis but bears on counsel question 1
Texas Data Privacy and Security Act	Mostly exempt as an SBA-defined small business. § 541.107 still applies	Small businesses are exempt from most of the Act but may not sell sensitive data without prior consent. "Sale" includes transfer for "monetary or other valuable consideration" (§ 541.001), which may describe images provided to the vendor for training in exchange for service. It excludes

Framework	Determination	Basis
		disclosure to a processor acting on the controller's behalf, which is unlikely to describe Oduya Imaging given that it trains on the images for its own purposes. "Sensitive data" covers biometric data processed to uniquely identify an individual, and Texas "biometric data" excludes photographs and data generated from them (§ 541.001), so whether D-1 or D-2 is sensitive data at all is referred to counsel with question 4
Florida Digital Bill of Rights, Fla. Stat. § 501.701 et seq.	Most of the Act not applicable. § 501.715 applies	Controller obligations require over $1 billion in global revenue plus other criteria, which Pineda does not meet. The sensitive-data sale provision applies to any for-profit business operating in Florida that collects personal data. Sensitive data includes biometric data processed to uniquely identify an individual, which SkinRead output likely is not. Referred to counsel together with the TDPSA sale question
FTC Act § 5 and FTC Policy Statement on Biometric Information (May 2023)	FTC Act § 5 applies. The Policy Statement is non-binding guidance	The Policy Statement states it does not bind the FTC or the public. It sets out the Commission's view that undisclosed biometric collection and use, and failing to evaluate and oversee vendors given access to biometric information, may be unfair or deceptive
HIPAA	Not applicable	Pineda is not a covered entity or business associate
CCPA/CPRA, Illinois BIPA	Not applicable	No California or Illinois locations. Reassess before expansion into IL, WA, or CA

6. Findings

Summary: 1 High, 2 Moderate, 1 Low, 1 unable to test.

F-01 · High · Images disclosed to vendor and kept indefinitely for model training

Condition. Section 7.3 of the Oduya Imaging order form (signed 2026-01-22) lets the vendor keep "de-identified" images to improve its models, with no retention limit. Full-face photos and 3D captures cannot be meaningfully de-identified. No data processing addendum exists. Clients have no way to request deletion from the vendor. The vendor's "process and discard" setting is available and was turned off.

Criteria. CUBI § 503.001(c)(1) restricts disclosure of a biometric identifier, and none of its four exceptions covers a processing vendor. The HB 149 amendments likely exempt the vendor's own training storage, but they do not obviously cure Pineda's act of disclosing the 3D captures to the vendor in the first place, and § 503.001(f) pulls training copies back under the destruction and penalty provisions if the vendor later uses them commercially outside the exemption. Separately, the vendor's training use may be a "sale" of sensitive data under TDPSA § 541.107 and Fla. Stat. § 501.715. The FTC biometric policy statement treats failure to oversee vendors handling biometric data as a potential unfair practice.

Cause. The retail marketing lead bought the kiosk on a standard order form. The vendor intake checklist had no question about client data, so the purchase never reached the operations director or counsel.

Effect. 3D captures of 37 Texas clients were disclosed to a vendor on terms Pineda cannot enforce. Across all locations, a breach at the vendor would expose facial images of 2,467 clients with no retention limit to point to.

Evidence reviewed. Oduya Imaging order form and online terms, retrieved 2026-07-09; vendor admin console, retention settings page, inspected 2026-07-21; vendor intake checklist, retail category; interview with retail marketing lead, 2026-07-14.

Rating note. Reviewed in v0.5 after confirming the HB 149 training exemption. Held at High: the exemption narrows the vendor-retention argument but leaves the disclosure question, the two sale-of-sensitive-data questions, and the absence of any DPA.

Recommendation.

1. Turn on "process and discard" in the vendor console. This takes minutes, costs nothing, and stops new accumulation while the DPA is negotiated.

2. Negotiate a DPA that ends training use of Pineda client images, requires deletion of images already held, sets a deletion SLA, warrants encryption at rest, and grants an audit right.

Management response. Concur. "Process and discard" enabled 2026-09-18. DPA target was 2026-08-26; moved to 2026-10-27 after Oduya Imaging's counsel rejected the first redline. Vendor counsel has since cited the HB 149 exemption in support of keeping historical images; deletion remains the open point. Intake question added 2026-08-04. Owner: Director of Operations.

F-02 · Moderate · Consent screen does not meet CUBI notice requirements

Condition. The "Advanced scan" screen shows one checkbox: "I agree to the terms and to receive personalized offers." It does not say a face-geometry record will be captured, that it goes to a third party, or how long it is kept. Marketing consent and scan consent share the same box.

Criteria. CUBI § 503.001(b) requires informing the individual and receiving consent before capturing a biometric identifier for a commercial purpose.

Cause. The screen is Oduya Imaging's default template. It is editable in the vendor console, and nobody at Pineda knew that.

Effect. 41 Texas 3D captures from 37 clients were taken under a notice that likely does not satisfy CUBI. At the § 503.001(d) maximum this is theoretical exposure of $925,000 on a per-client count, and a CUBI violation is also a TRAIGA § 552.054 violation with its own penalty range. Practical exposure is probably lower than either figure suggests: if the AG proceeds under TRAIGA, it has exclusive enforcement and must give 60 days' written notice and an opportunity to cure under § 552.104, and the fix here is a console setting. A direct action under § 503.001(d) carries no statutory cure period, and whether § 552.054(c) displaces that route is a counsel question. The numbers size the decision in §7; they are not a forecast.

Evidence reviewed. Kiosk screenshots from Kemah and Pearland, 2026-07-21; vendor console consent configuration page.

Recommendation. Put Texas kiosks in 2D-only mode (a console setting) until the new consent screen is live. Then rewrite the screen to name Oduya Imaging, the purpose, and retention, with marketing opt-in as a separate unchecked box.

Management response. Partially concur. Management still regards the rating as overstated given the small number of clients affected. 2D-only mode scheduled for 2026-09-25. **Assessor position:** rating stays Moderate. The client count bounds the exposure but does not cure the notice.

F-03 · Moderate · Before/after photos on personal phones with no policy

Condition. Four of the six stylists interviewed photograph clients' faces and hair on personal phones for before/after comparisons and social media. Three of the four work at W-2 locations; one rents a booth at Pearland. Photos stay in personal camera rolls, and two stylists back them up to personal cloud accounts. No written policy covers this and no photo release is collected.

Criteria. FTC Act § 5 applies to undisclosed uses of consumer images. Pineda's Client Privacy Notice (rev. 2025-11) said client images are "used only to provide your service."

Cause. The company has avoided issuing device rules to any stylist because of worker-classification concerns about booth renters, and that caution was applied to W-2 staff as well, where it does not apply.

Effect. The published privacy notice was inaccurate. At W-2 locations, client images sit on devices Pineda cannot inventory or wipe at separation.

At booth-rental locations the position is different. The renter is a separate business, and clients who book directly with a renter are arguably the renter's clients. Pineda's exposure there comes from its own privacy notice and brand signage implying company-wide coverage.

Evidence reviewed. Stylist interviews at Cocoa Village, Merritt Island, Winter Park, Kemah, Pearland, and Viera, 2026-07-28 to 2026-08-06; Client Privacy Notice rev. 2025-11; standard booth rental agreement (2024 form).

Recommendation.

1. W-2 locations: issue a service-photo standard covering client consent, upload to a company-controlled album, and deletion from personal devices after upload.
2. Booth-rental locations: add a privacy clause to the rental agreement at next renewal requiring renters to follow equivalent practice or post their own notice. Narrow the Pineda privacy notice so it does not claim to cover renter services.

Management response. Concur. Privacy notice corrected 2026-09-02. W-2 standard drafted, awaiting employment counsel. Booth rental renewals fall in January 2027. No target date committed for the W-2 standard.

F-04 · Unable to test · Vendor encryption at rest

Condition. The assessor could not determine whether Oduya Imaging encrypts D-1 and D-2 at rest.

Detail. A SOC 2 Type II report was requested 2026-07-08 and again 2026-08-03. The vendor will share it only under a mutual NDA, which Pineda has not signed. The vendor's security page says data is "encrypted," with no scope given.

Disposition. Testing limitation, no rating. CUBI § 503.001(c)(2) requires reasonable care in storing and transmitting biometric identifiers, so this gap bears on Texas compliance as well as security. The encryption warranty in the F-01 DPA covers it contractually. The report should still be obtained to test it.

Evidence reviewed. Request emails of 2026-07-08 and 2026-08-03; vendor reply of 2026-08-05; Oduya Imaging security page, retrieved 2026-07-09.

F-05 · Low · No retention schedule for kiosk results in the booking platform

Condition. Thumbnails (D-3) and skin reports (D-4) are kept for as long as the client account exists. The platform supports automated deletion of attachments by age, and it is not configured. Some records already belong to clients who have not returned since the week of go-live.

Criteria. CUBI's destruction requirement does not clearly reach a 2D thumbnail, but the FTC policy statement and general data-minimization practice both point to retention tied to purpose.

Cause. Retention was never considered for kiosk output because the kiosk was treated as a retail tool (same cause as F-01).

Effect. Limited. Thumbnails are low resolution and reports hold no identifiers beyond the client record they are attached to. Exposure grows with time.

Evidence reviewed. Booking platform attachment settings, 2026-08-12; export of client records with kiosk attachments, 2026-08-12.

Recommendation. Set automated deletion of kiosk attachments 18 months after the client's last visit.

Management response. Concur. Target 2026-11-25.

7. Accepted and escalated risks

ID	Risk	Rationale	Decision	Review date
AR-1	Kiosks at Cocoa Village and Merritt Island share a network segment with guest Wi-Fi	Network refresh at both older locations is in the FY2027 capital budget. Interim control: vendor console restricted to vendor IP allowlist	Accepted by Lorraine Batiste, Chief Operating Officer	2027-01-12
AR-2	3D capture continued in Texas under the v0.3 consent screen	v0.3 recorded management's decision not to suspend	**Superseded.** Assessor did not support acceptance, because a likely statutory violation is not a risk the COO can accept alone. Resolved by 2D-only mode under F-02. Captures already taken are addressed under F-01 deletion	Closed on confirmation of 2D-only mode

8. Remediation plan

Item	Finding	Owner	Effort	Cost	Target	Status
Enable "process and discard"	F-01	Dir. of Operations	Under 1 hour	None	2026-09-18	Done
Texas kiosks to 2D-only	F-02	Dir. of Operations	Under 1 hour	None	2026-09-25	Scheduled
Executed DPA with deletion of historical images	F-01, F-04	Dir. of Operations, outside counsel	Weeks	Counsel fees, est. $3,000–$5,000	2026-10-27 (slipped from 2026-08-26)	In negotiation
Rewrite consent screen	F-02	Retail marketing lead	1–2 days	None	2026-10-20	Not started

Item	Finding	Owner	Effort	Cost	Target	Status
W-2 service-photo standard	F-03	HR, employment counsel	1–2 weeks	Counsel fees	None committed	Drafted
Booth rental privacy clause	F-03	Owner	At renewal	None	2027-01 renewals	Not started
Attachment retention rule	F-05	Front-office manager	Under 1 day	None	2026-11-25	Not started
Obtain SOC 2 under NDA	F-04	Dir. of Operations	Days	None	2026-10-20	NDA with counsel

9. Residual risk and open questions

Residual risk is Moderate once the two console changes are confirmed, and depends on the DPA closing by 2026-10-27. If it slips again, the assessor recommends turning off 3D capture at all nine locations until it is signed.

Questions for counsel:

1. Does a 2D facial photo used only for skin analysis fall within CUBI's definition of a biometric identifier?
2. Is transmitting D-2 to Oduya Imaging a disclosure under § 503.001(c)(1), given that no listed exception covers a processing vendor?
3. Does the § 503.001(e)(2) exemption for "otherwise offering" an AI system reach Pineda as a deployer, or only Oduya Imaging as developer? If the vendor keeps historical images under that exemption, does § 503.001(f) reattach CUBI duties when those images support a commercial product?
4. Is providing images to the vendor for training, in exchange for the service, a "sale" of sensitive data under TDPSA § 541.107 or Fla. Stat. § 501.715?

10. Sources checked

Claim	Source
CUBI consent, disclosure exceptions, reasonable care, destruction, $25,000 penalty	Tex. Bus. & Com. Code ch. 503, statutes.capitol.texas.gov/Docs/BC/htm/BC.503.htm
CUBI obligations summary	Texas Attorney General, texasattorneygeneral.gov, Biometric Identifier Act page
HB 149 § 503.001(e)(2) and (f), § 552.054(c), § 552.104 cure period, § 552.105 penalties, effective 2026-01-01	Enrolled bill text, capitol.texas.gov/tlodocs/89R/billtext/html/HB00149F.HTM, reviewed 2026-09-25
TDPSA small-business exemption and § 541.107	Perkins Coie; Vinson & Elkins
FDBR controller thresholds and § 501.715 sale provision	Bass Berry & Sims; White & Case

Version history

Version	Date	Author	Changes
0.1	2026-08-11	C. Morrissey	Initial draft covering vendor contract and consent screen
0.2	2026-08-27	C. Morrissey	Added F-03 after stylist interviews. Encryption item moved from a Low finding to "unable to test" after the vendor declined to share SOC 2 without an NDA
0.3	2026-09-18	C. Morrissey	Management responses added. F-02 severity dispute recorded; AR-1 and AR-2 added
0.4	2026-09-21	C. Morrissey	Added method, rating scale, necessity section, F-05, and remediation plan. Corrected client counts. Rescoped F-03 for booth renters. F-02 recommendation changed to 2D-only mode. AR-2 superseded

Version	Date	Author	Changes
0.5	2026-09-24	C. Morrissey	Legal claims checked against sources. FDBR corrected from "not applicable" to § 501.715 applying. HB 149 exemption confirmed and F-01 criteria revised around it; F-01 rating reviewed and held. CUBI disclosure exceptions stated. Added §10
0.6	2026-09-25	C. Morrissey	HB 149 verified against the enrolled bill text, replacing law-firm summaries. Added § 503.001(f) and the § 552.054(c) penalty routing. F-02 effect revised to note the 60-day cure period, which lowers practical exposure